

Botium Toys — Controls and Compliance Checklist

Completed by: Stacey Munnik

Reference: Botium Toys Scope, Goals, and Risk Assessment Report; Control Categories document.

Controls Assessment Checklist

Question: Does Botium Toys currently have this control in place?

Yes	No	Control
☐	☒	Least Privilege
☐	☒	Disaster recovery plans
☒	☐	Password policies
☐	☒	Separation of duties
☒	☐	Firewall
☐	☒	Intrusion detection system (IDS)
☐	☒	Backups
☒	☐	Antivirus software
☒	☐	Manual monitoring, maintenance, and intervention for legacy systems
☐	☒	Encryption
☐	☒	Password management system
☒	☐	Locks (offices, storefront, warehouse)
☒	☐	Closed-circuit television (CCTV) surveillance
☒	☐	Fire detection/prevention (fire alarm, sprinkler system, etc.)

Compliance Checklist

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice
☐	☒	Only authorized users have access to customers' credit card information.
☐	☒	Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment.
☐	☒	Implement data encryption procedures to better secure credit card transaction touchpoints and data.
☐	☒	Adopt secure password management policies.

General Data Protection Regulation (GDPR)

Yes	No	Best practice
☐	☒	E.U. customers' data is kept private/secured.
☒	☐	There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.
☐	☒	Ensure data is properly classified and inventoried.
☒	☐	Enforce privacy policies, procedures, and processes to properly document and maintain data.

System and Organization Controls (SOC Type 1, SOC Type 2)

Yes	No	Best practice
☐	☒	User access policies are established.
☐	☒	Sensitive data (PII/SPII) is confidential/private.
☒	☐	Data integrity ensures the data is consistent, complete, accurate, and has been validated.
☒	☐	Data is available to individuals authorized to access it.

Recommendations

Botium Toys' overall risk posture is high, driven primarily by two gaps: broad, unrestricted internal access to sensitive data (cardholder data and customer PII/SPII), and the absence of encryption, backups, and disaster recovery planning.

Recommended priorities, in order:

1. Implement least privilege and separation of duties immediately — restrict cardholder data and PII/SPII access to only the roles that require it. This single change addresses the root cause behind the PCI DSS and SOC failures above.
2. Encrypt cardholder data and other sensitive data at rest and in transit, and adopt a centralized password management system enforcing modern complexity requirements (minimum 8 characters, mixed case, numbers, special characters).

3. Establish backups and a documented disaster recovery plan to ensure business continuity in the event of an incident.
4. Deploy an IDS to detect anomalous or malicious traffic, complementing the existing firewall.
5. Complete a full asset inventory and classification exercise (NIST CSF Identify function) — this is a prerequisite for accurately scoping GDPR data protection obligations and prioritizing which assets need the controls above most urgently.
6. Formalize a maintenance schedule for legacy system monitoring rather than relying on ad hoc intervention.